

Daily Vulnerability Report - 2026-09-28

Window (UTC): 2026-09-27T05:55 to 2026-09-28T05:55 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-28 05:55:23 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
154	137	17	0	2	11	47	67	11	109

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88771	New	9.5	CRIT	Yes		citrix:netscaler	Improper input validation vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to an unauthenticated attacker to execute arbitrary commands.
CVE-2026-88772	New	9.5	CRIT	Yes		citrix:netscaler	Vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to Remote Code Execution or Denial of Service
CVE-2026-100886	New	10.0	CRIT				A vulnerability was identified in Seetong T8108, T8108P, T8116 and T8232 4.6.1.4-build202604241011. The affected element is an unknown function of the component Debug Service. Such manipulation leads to improper authentication. The attack may be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101000	New	10.0	CRIT				A vulnerability was determined in Netcore NBR100V2 1.3.240614.030928. This affects the function uci.apply of the file /usr/share/rpcd/acl.d/unauthenticated.json of the component ACL Handler. This manipulation of the argument section causes missing authorization. It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be utilized. The v...
CVE-2026-101001	New	10.0	CRIT				A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This impacts the function eval of the file /www/cgi-bin/network_tools of the component Web Management Interface. Such manipulation of the argument QUERY_STRING leads to os command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used. The vendor was co...
CVE-2026-100896	New	9.9	CRIT				A weakness has been identified in TOTOLINK N150RT 3.4.0-B20201030. The affected element is the function system of the file /boafrm/formWISiteSurvey of the component Web Management Interface. This manipulation of the argument wlanif causes os command injection. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100741	New	9.8	CRIT		0.017		Eval injection in the JScript event-script dispatcher in Progressive Robot Ltd's hMailServer, versions 6.0.0 through 6.3.3 on Windows, allows a remote, unauthenticated attacker to run arbitrary JScript inside the hMailServer service process, with the privileges of the service account, via a password containing a backslash followed by an apostrophe, sent in any logon (SMTP AU...
CVE-2026-101065	New	9.8	CRIT				Obot is an open-source AI agent/MCP platform. In all versions up to and including commit d7e6970, the Docker quickstart command documented in the README starts the container listening on 0.0.0.0:8080 with authentication disabled by default. When authentication is disabled, every request is mapped to a synthetic "nobody" user that holds the Owner and Admin roles, so any unaut...
CVE-2026-101090	New	9.8	CRIT				Nezha 2.2.3 contains a Host header injection regression in the OAuth2 redirect endpoint. When the new optional dashboard_host setting is empty, /api/v1/oauth2/{provider} (cmd/dashboard/controller/oauth2.go) reflects the attacker-supplied HTTP Host header into the redirect_uri sent to the identity provider instead of falling back to the configured install_host. An attacker wh...
CVE-2026-101084	New	9.6	CRIT				obot versions before v0.21.1 fail to enforce Access Control Rules on the /mcp-connect endpoint, allowing any authenticated user to connect to restricted MCP servers if they possess the server ID. Attackers can bypass authorization checks to access and manipulate sensitive backend systems through MCP tool calls using stored OAuth credentials.
CVE-2026-88773	New	9.3	CRIT				Inconsistent interpretation of HTTP requests ('HTTP Request/Response smuggling') vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1-37.279 and NDcPP; Gateway: before 14.1-73.37 FIPS and before 13.1-64.23.
CVE-2026-100870	New	8.8	HIGH				Syllus versions before 1.12.25, 1.13.17, 1.14.20, 2.1.16, and 2.2.9 build administrator password-reset links using the request Host header without validation, allowing unauthenticated attackers to redirect reset tokens to attacker-controlled domains. Attackers can request password resets for known administrator email addresses with forged Host headers to intercept valid rese...
CVE-2026-100871	New	8.8	HIGH				Syllus versions before 1.12.25, 1.13.17, 1.14.20, 2.1.16, and 2.2.9 fail to include firewall identification in JWT tokens issued by separate Admin and Shop API endpoints. Attackers can register a shop customer account using an administrator's email address and obtain a token that the Admin API resolves to that administrator, granting full administrative access.
CVE-2026-101062	New	8.8	HIGH				Obot before v0.23.0 (affected versions <= v0.22.1) running with OBOT_SERVER_ENABLE_AUTHENTICATION=true exposes OAuth dynamic client registration without authentication and without any restriction on the redirect URIs a client may register. Because the authorization flow auto-completes for an already logged-in user with no consent screen, an attacker who registers a client po...
CVE-2026-86609	New	8.8	HIGH		0.002		The Download Manager WordPress plugin before 7.5.6 does not sanitise and escape data submitted through its email-locked download subscription form before outputting it back in an admin page, which could allow unauthenticated attackers to perform Stored Cross-Site Scripting attacks against administrators. This affects the commercial Pro edition only; the free Download Manager...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88775	New	8.8	HIGH				Memory overflow vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading Memory overflow vulnerability leading to unpredictable or erroneous behavior or Denial of Service
CVE-2026-88776	New	8.8	HIGH				Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service
CVE-2026-88777	New	8.8	HIGH				Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service
CVE-2026-88778	New	8.8	HIGH				Predictable exact value from previous values vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23.
CVE-2026-89102	New	8.3	HIGH		0.003		In wolfSSL versions 5.7.2 through 5.9.2 there is a client-side implementation flaw in RFC 6961, multiple OCSP response stapling, which can lead to certificate forgery. When a wolfSSL client enables OCSP stapling with the HAVE_CERTIFICATE_STATUS_REQUEST_V2 feature and calls wolfSSL_UseOCSPStaplingV2(ssl, WOLFSSL_CSR2_OCSP_MULTI, options), the client accepts any certificate in...
CVE-2026-89136	New	8.3	HIGH		0.006		When using RPK (Raw Public Key), the client side of a TLS 1.2, 1.3 and DTLS 1.2 connection could accept an unsolicited server_cert_type=RawPublicKey which allowed a malicious or misbehaving server to bypass authentication. RPK is off by default and only enabled in --enable-rpk OR --enable-all OR --enable-distro AKA HAVE_RPK builds.
CVE-2026-93302	New	8.3	HIGH		0.004		MatchTrustedPeer ignores the public key used, leading to forged CA clones passing verification. Affected builds are any that enable the macro WOLFSSL_TRUST_PEER_CERT and load CA certificates with wolfSSL_CTX_trust_peer_cert() or wolfSSL_trust_peer_cert(). The peer must know the certificates being loaded to either of those APIs to take advantage of the issue. When OPENSSL_COM...
CVE-2026-101060	New	8.2	HIGH				python-utcp versions before 1.1.4 contain a server-side request forgery vulnerability in HttpCommunicationProtocol.call_tool that validates the initial tool URL but follows HTTP redirects without re-validating the target. Attackers controlling a tool endpoint can return a 302 redirect to internal services, allowing the UTCP client to reach cloud metadata endpoints or interna...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101045	New	8.0	HIGH				Fleet-maintained app install and uninstall scripts for macOS are generated from Homebrew cask metadata. In manifests generated before 2026-08-19, the script generator escaped this metadata at some interpolation sites but not all of them, so cask metadata containing shell metacharacters (for example \$(...) command substitution) could be carried into scripts that execute as ro...
CVE-2026-101064	New	7.6	HIGH				Obot before v0.23.0 contains a server-side request forgery vulnerability in remote MCP server registration that allows privileged users to specify arbitrary URLs without destination validation. Attackers with Power User or higher roles can coerce Obot to make requests to internal services and cloud metadata endpoints, reading responses in error messages to disclose sensitive...
CVE-2026-100872	New	7.5	HIGH				Syllus versions before 2.1.16 and 2.2.9 fail to validate payment amounts during cart recalculation, allowing unauthenticated attackers to modify order totals after gateway transaction initiation. Attackers can pay a small amount, enlarge the order after gateway capture, and have the system mark the inflated order as fully paid while the gateway captured only the original amo...
CVE-2026-100908	New	7.5	HIGH				A vulnerability has been found in Eyeplus 57.0.0.0308. This affects an unknown function of the component p2pcam HTTP Parser. Such manipulation leads to stack-based buffer overflow. The attack may be performed from remote. The exploit has been disclosed to the public and may be used.
CVE-2026-81655	New	7.5	HIGH		0.002		The Ad Inserter WordPress plugin before 2.8.19 does not correctly restrict access to one of its settings pages, making it reachable by every logged in user under a configuration its own settings allow, and does not filter the content saved there, allowing users with a role as low as subscriber to store code which is then executed as PHP or served unescaped to site visitors.
CVE-2026-96280	New	7.5	HIGH				The OCI delta stream parser read sizes as quint64 but passed them to GLib I/O and allocation functions expecting gsize (32 bits on 32-bit systems), causing undersized allocations while subsequent operations use the original 64-bit size, leading to heap buffer overflows. An attacker controlling an OCI registry can craft a delta stream that triggers this during flatpak install...
CVE-2026-101043	New	7.4	HIGH				pnpm versions 11.0.0 before 11.11.0 and 10.7.0 before 10.34.5 expand \${VAR} environment-variable placeholders in the httpProxy, httpsProxy, and noProxy settings read from a project's pnpm-workspace.yaml. Because the manifest is repository-controlled and the proxy keys were omitted from the request-destination key set that otherwise suppresses placeholder expansion for untrus...
CVE-2026-100874	New	7.3	HIGH				A flaw has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This affects an unknown function of the file addnewstudent.php. This manipulation causes sql injection. The attack may be initiated remotely. The exploit has been published and may be used. This product uses a rolling release model to deliver continuous updates. A...
CVE-2026-100875	New	7.3	HIGH				A vulnerability has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file updatedetailsfromfaculty.php. Such manipulation of the argument myfid leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used. This product oper...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100885	New	7.3	HIGH				A vulnerability was found in Krayin laravel-crm up to 2.2.4. This affects an unknown function of the file packages/Webkul/Installer/src/Http/Middleware/CanInstall.php of the component admin-config-setup API Endpoint. The manipulation results in authorization bypass. The attack may be launched remotely. The exploit has been made public and could be used. Upgrading to version ...
CVE-2026-100888	New	7.3	HIGH				A weakness has been identified in Trusted Domain Project OpenDKIM up to 2.11.0. This affects the function dkim_canon_selecthdrs of the file libopendkim/dkim-canon.c of the component DKIM Signature Header Selection. Executing a manipulation of the argument h can lead to out-of-bounds write. The attack can be executed remotely. The exploit has been made available to the public...
CVE-2026-100889	New	7.3	HIGH				A vulnerability was detected in Trusted Domain Project OpenDKIM up to 2.11.0. Affected is the function dkim_qp_decode of the file util.c of the component Decoder. The manipulation results in off-by-one. The attack may be performed from remote. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-100891	New	7.3	HIGH				A vulnerability has been found in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this issue is the function opendmarc_policy_query_dmarc in the library libopendmarc/opendmarc_policy.c of the component Internationalized Domain Name Handler. Such manipulation leads to encoding error. It is possible to launch the attack remotely. The exploit has been disclosed to the...
CVE-2026-100893	New	7.3	HIGH				A vulnerability was determined in Privece VoceChat Server up to 0.5.36. This vulnerability affects the function open_graph::fetch of the file src/api/resource.rs of the component open_graphic_parse Endpoint. Executing a manipulation of the argument url can lead to server-side request forgery. The attack can be launched remotely. The exploit has been publicly disclosed and ma...
CVE-2026-100901	New	7.3	HIGH				A vulnerability was found in athlon1600 youtube-downloader up to 4.0.1. Affected by this vulnerability is the function stream of the file public/stream.php. The manipulation of the argument url results in server-side request forgery. It is possible to launch the attack remotely. The exploit has been made public and could be used. Commit 6ffe823 'better security for public/st...
CVE-2026-100909	New	7.3	HIGH				A vulnerability was found in OctoberCMS up to 4.1.19/4.2.25/4.3.4. The impacted element is the function getSourcePathForResize of the file modules/system/classes/ResizeImages.php. The manipulation of the argument realSourcePath results in server-side request forgery. The attack may be performed from remote. The exploit has been made public and could be used. Upgrading to ver...
CVE-2026-96896	New	7.2	HIGH		0.002		The Malcure Malware Shield — Removal, Repair, Monitor WordPress plugin before 19.9.7 does not perform an authorisation check on one of its AJAX actions, allowing users with a subsite administrator role on a multisite network to write and delete arbitrary files in the network's shared filesystem, which can lead to remote code execution.
CVE-2026-101044	New	7.1	HIGH				pacquet, the Rust package-manager component shipped in the pnpm npm package versions >=12.0.0-alpha.0 and <12.0.0-alpha.5, does not validate dependency alias/name paths taken from a lockfile before using them in install-time filesystem joins. When a user installs a project with an attacker-supplied lockfile using --trust-lockfile or a frozen lockfile, alias entries containin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101059	New	7.1	HIGH				utcp-http before 1.1.4 fails to validate the OAuth2 tokenUrl field from remote OpenAPI specifications, allowing attackers to redirect credential submission to arbitrary endpoints. When a victim registers an attacker-controlled OpenAPI spec and invokes a generated OAuth2-protected tool, the library POSTs the victim's client_id and client_secret to the attacker-supplied token ...
CVE-2026-101032	New	7.0	HIGH				navi through 2.24.0 fails to properly escape cheatsheet variable values when substituting them into shell commands. Attackers can inject shell metacharacters through crafted file names in suggestion command directories to execute arbitrary commands with victim privileges.
CVE-2026-88774	New	7.0	HIGH				Vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to a feature policy bypass due to improper HTTP URL based expression usage.
CVE-2026-97164	New	7.0	HIGH				Joomla Extension - svenbluege.de - Authenticated arbitrary path deletion in `clear cache` task in Event Gallery extension < 6.5.0 - Using the `images` parameter of the `cache.process` task, you can recursively delete any directories that the web server is authorized to write to.
CVE-2026-100748	New	6.9	MEDI				Joomla Extension - svenbluege.de - CSRF in various cart actions in Event Gallery extension < 6.5.0
CVE-2026-101058	New	6.9	MEDI				python-utcp (pip package utcp-http) before 1.1.12 does not verify whether tool URLs declared in a hand-written UTCP manual point at the agent's own loopback interface when that manual is discovered from a remote, non-loopback origin. Because ensure_secure_url intentionally permits loopback HTTP for local development and native manuals bypassed the loopback check performed by...
CVE-2026-85002	New	6.8	MEDI		0.002		The EmbedPress WordPress plugin before 4.6.7 does not escape one of its block attributes before outputting it inside an HTML attribute, which could allow users with the contributor role and above to perform Stored Cross-Site Scripting attacks against higher privileged users viewing the post.
CVE-2026-89006	New	6.8	MEDI		0.002		The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.27 does not sanitize imported feed content before storing it as post content, allowing users with the Contributor role and above to perform Stored Cross-Site Scripting attacks.
CVE-2026-96895	New	6.8	MEDI		0.002		The WP YouTube Lyte WordPress plugin before 1.7.31 does not escape some attributes of YouTube embed blocks before outputting them in an HTML attribute when rendering the block, which could allow users with a role as low as contributor to perform Stored Cross-Site Scripting attacks.
CVE-2026-96899	New	6.8	MEDI		0.002		The Optima Express IDX WordPress plugin before 8.7.6 does not properly neutralise a script value submitted through one of its REST endpoints before storing it and echoing it into the document head when the post is rendered, allowing users with a role as low as author to perform Stored Cross-Site Scripting attacks.
CVE-2026-97319	New	6.8	MEDI		0.002		The PowerPress Podcasting plugin by Blubrry WordPress plugin before 11.17.2 does not sanitize and escape a block attribute before outputting it in a page, which could allow users with the contributor role and above to perform Stored Cross-Site Scripting attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100902	New	6.5	MEDI				A vulnerability was determined in Barco ClickShare CX-20 Gen2 up to 02.26.00.0007. Affected by this issue is some unknown functionality of the file /wallpaper of the component Wallpaper Upload. This manipulation of the argument wallpaper causes denial of service. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was...
CVE-2026-101049	New	6.5	MEDI				Heym before 0.0.53 fails to verify Slack request signatures when trigger nodes lack credential IDs or have empty signing secrets. Remote unauthenticated attackers can send forged Slack events to known webhook URLs to trigger workflows with the owner's credentials.
CVE-2026-101050	New	6.5	MEDI				Heym before 0.0.53 fails to verify the X-Telegram-Bot-API-Secret-Token header on Telegram webhook endpoints when credential_id is absent or secret_token is empty. Remote unauthenticated attackers can post forged Telegram updates to trigger workflows with the owner's configured credentials and execute actions on attacker-supplied input.
CVE-2026-101085	New	6.5	MEDI				Nezha before 2.3.8 fails to validate alert rule type and duration bounds, allowing authenticated non-administrator users to create malformed rules that trigger unrecovered panics in the alert evaluator goroutine. Attackers can submit a crafted alert rule via the POST /api/v1/alert-rule endpoint to crash the dashboard process, which persists the rule and causes repeated crash...
CVE-2026-101086	New	6.5	MEDI				Nezha Dashboard versions before 2.3.5 fail to restrict service monitor task types to supported probe types, allowing authenticated users with nezha.service:write scope to submit privileged task types through the service API. Attackers can deliver command execution or Agent configuration tasks to Agents within their authorization scope by exploiting the shared protobuf Task.T...
CVE-2026-96279	New	6.5	MEDI				A malicious OCI registry can hardlink arbitrary host files into the extraction directory when a user installs or updates a Flatpak application from an OCI remote, allowing disclosure of arbitrary host file contents. For system-wide installs running as root, this includes sensitive files such as /etc/shadow.
CVE-2026-101042	New	6.4	MEDI				Parse Server is an open-source backend server. In versions >= 9.0.0 < 9.10.1-alpha.10 and >= 8.0.2 < 8.6.91, the code-based authentication adapters (GitHub, Google Play Games, Instagram, LINE, LinkedIn, Microsoft, QQ, Spotify, WeChat, Weibo) verify the client's authorization code with the external provider on signup and on provider linking, but not when authentication data i...
CVE-2026-100868	New	6.3	MEDI				Penpot before 2.18.0 binds the MCP server plugin WebSocket bridge to all network interfaces without authentication in single-user mode. Unauthenticated attackers on adjacent networks can connect to the WebSocket port to impersonate the Penpot browser plugin, intercept task payloads, and return forged results to the MCP client.
CVE-2026-100876	New	6.3	MEDI				A vulnerability was found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. Affected is an unknown function of the file loginlinkstudent.php. Performing a manipulation of the argument umail results in missing authentication. Remote exploitation of the attack is possible. The exploit has been made public and could be used. This product...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100878	New	6.3	MEDI				A vulnerability was identified in zhigaredu StarTraining up to 3.8.1. Affected by this issue is the function SysUser.isAdmin of the file edu-common/src/main/java/com/edu/common/core/domain/entity/SysUser.java of the component authRole Endpoint. The manipulation of the argument userId/roleIds leads to authorization bypass. The attack is possible to be carried out remotely. T...
CVE-2026-100883	New	6.3	MEDI				A flaw has been found in Krayin laravel-crm up to 2.2.5. The affected element is an unknown function of the file packages/Webkul/Admin/src/Config/acl.php. Executing a manipulation can lead to improper access controls. The attack can be launched remotely. The exploit has been published and may be used. Upgrading to version 2.2.6 is sufficient to fix this issue. This patch is ...
CVE-2026-100887	New	6.3	MEDI				A security flaw has been discovered in amirsanni Mini-Inventory-and-Sales-Management-System up to 81bf0b55f5933f3b0dbb1583204a612e06605b95. The impacted element is the function order_by of the file DB_query_builder.php of the component Database Query Builder. Performing a manipulation of the argument orderBy results in sql injection. Remote exploitation of the attack is poss...
CVE-2026-100894	New	6.3	MEDI				A vulnerability was identified in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This issue affects some unknown processing of the file updateguest.php. The manipulation of the argument gname leads to sql injection. The attack may be initiated remotely. The exploit is publicly available and might be used. This product uses a rolling r...
CVE-2026-100898	New	6.3	MEDI				A vulnerability was detected in DevaslanPHP project-management 1.2.1/1.2.2/1.2.3/1.2.4/2.0.0-beta1. This affects the function whereRaw of the file app/Filament/Widgets/Timesheet/ActivitiesReport.php of the component Timesheet Dashboard. Performing a manipulation of the argument filter results in sql injection. The attack is possible to be carried out remotely. The exploit is...
CVE-2026-100899	New	6.3	MEDI				A flaw has been found in DevaslanPHP project-management 1.2.1/1.2.2/1.2.3/1.2.4/v2.0.0-beta1. This impacts the function whereRaw of the file app/Filament/Widgets/Timesheet/MonthlyReport.php of the component Timesheet Dashboard. Executing a manipulation of the argument filter can lead to sql injection. The attack may be performed from remote. The exploit has been published an...
CVE-2026-101041	New	6.3	MEDI				The account recovery (password reset) functionality in the vulnerability-lookup web application contains a time-of-check-to-time-of-use (TOCTOU) race condition in the consumption of single-use recovery tokens. The original implementation verified the token nonce against the stored digest and then consumed (cleared) it in separate database operations. Two concurrent HTTP requ...
CVE-2026-89133	New	6.3	MEDI		0.002		wolfSSL versions 5.9.2 and earlier contain a flaw in the X.509 certificate validation logic where it fails to properly enforce NameConstraints extensions when there is an unconstrained CA tier between a name-constrained intermediate CA and the leaf certificate. wolfSSL incorrectly accepted certificates for hostnames they shouldn't be allowed to cover, due to a chain-walking ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89134	New	6.3	MEDI		0.002		A certificate with no dNSName SAN but another SAN type present (e.g. registeredID or iPAddress) bypassed the Subject CN dNSName name-constraint check. The CN-as-DNS fallback was gated on cert->subjectCN != NULL && cert->altNames == NULL && !cert->isCA instead of "no dNSName SAN", so an out-of-scope CN was accepted. This incomplete fix from CVE-2026-6731, leading to the name-...
CVE-2026-89135	New	6.3	MEDI		0.002		A failed X509_verify_cert call permanently plants an unverified attacker CA in the shared CertManager, bypassing certificate validation in every type-blind sibling consumer (native TLS, OCSP, CRL, direct CM verify). This affects version 5.8.4 through 5.9.2 of wolfSSL with the macros (OPENSSL_EXTRA && !NO_CERTS && !WOLFCRYPT_ONLY) defined or built with --enable-opensslextra a...
CVE-2026-93304	New	6.3	MEDI		0.002		A (D)TLS 1.2 client can accept a ChangeCipherSpec message before it has sent its ClientKeyExchange. No master secret has been derived at that point, so the client installs read keys derived from a known (deterministic) key and checks the server's Finished against that same key. An out-of-order ChangeCipherSpec can therefore be used by an attacker to complete the handshake in...
CVE-2026-96281	New	6.2	MEDI				On a multi-user system, a user with an active local login session could downgrade a system-wide Flatpak app to an older version by removing the app's remote ref via the unprivileged system-helper RemoveLocalRef method, causing the anti-downgrade check to fail to find a reference date. A malicious local user could use this to expose other users of the same system to an app ve...
CVE-2026-100869	New	5.9	MEDI				Syllus versions before 2.1.16 and 2.2.9 fail to restrict payment request actions in the Shop API endpoint, allowing customers to trigger refunds on completed orders. Attackers with order tokens can submit arbitrary payment actions like refunds that payment gateways execute while Syllus maintains order as paid, causing financial loss.
CVE-2026-97227	New	5.9	MEDI		0.001		The NextScripts: Social Networks Auto-Poster WordPress plugin before 4.4.8 does not perform capability or ownership checks on several of its AJAX actions, relying on a nonce alone, allowing users an administrator has granted access to its posting features to export the site's configured social account credentials, delete arbitrary posts and reset the NextScripts: Social Netw...
CVE-2026-100897	New	5.5	MEDI				A security vulnerability has been detected in fuzui StudentInfo up to fcc42a639ec7cef620651bfd0f07ebb660529e3f. The impacted element is an unknown function of the file /StudentInfo/StudentHandler/moditypasswordstu of the component Password Change Endpoint. Such manipulation of the argument sid/tid leads to authorization bypass. The attack can be executed remotely. This produ...
CVE-2026-100900	New	5.5	MEDI				A vulnerability has been found in DevaslanPHP project-management 1.2.1/1.2.2/1.2.3/1.2.4/v2.0.0-beta1. Affected is the function updateJiraProjects of the file /jira-import of the component Jira Import. The manipulation of the argument host/username/token leads to server-side request forgery. It is possible to initiate the attack remotely. The exploit has been disclosed to th...
CVE-2026-101048	New	5.4	MEDI				Cloudevre before 4.17.0 registers the administrative node test endpoints (POST /api/v4/admin/node/test and POST /api/v4/admin/node/test/downloader) without requiring the Admin.Write OAuth scope, unlike the node create/update/delete routes. An OAuth client that has been authorized by an administrator with only the Admin.Read scope can therefore submit attacker-controlled node...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87723	New	5.4	MEDI				In Google fuse-archive versions prior to 1.24, an attacker who can prepend a directory to PATH or write a malicious binary to an attacker-controlled or writable directory appearing in PATH can hijack the execution pathway. This allows the attacker to execute arbitrary local code under the security context of the user running the fuse-archive process. The issue was partially ...
CVE-2026-100890	New	5.3	MEDI				A flaw has been found in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this vulnerability is the function opendmarc_spf_ipv6_explode in the library libopendmarc/opendmarc_spf.c of the component SPF Parser. This manipulation of the argument cp causes null pointer dereference. It is possible to initiate the attack remotely. The exploit has been published and may be...
CVE-2026-100892	New	5.3	MEDI				A vulnerability was found in aligunr UERANSIM up to 3.3.0. This affects the function ULInformationTransfer of the file src/gnb/rrc/handler.cpp of the component nr-gnb. Performing a manipulation of the argument dedicatedNASMessage results in memory corruption. The attack can be initiated remotely. The exploit has been made public and could be used. The vendor was contacted e...
CVE-2026-100895	New	5.3	MEDI				A security flaw has been discovered in Trusted Domain Project OpenARC up to 1.0.0.Beta1. Impacted is the function arc_parse_canon_t in the library libopenarc/arc-canon.c of the component libopenarc. The manipulation results in null pointer dereference. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks. Upgrading to v...
CVE-2026-100903	New	5.3	MEDI				A vulnerability was identified in ■■■■ ■■■■ ■■■■ GEOritm up to 2.45.1. This affects an unknown part of the file /restapi/objects/obj-groups of the component REST API. Such manipulation of the argument objectId leads to missing authentication. The attack can be launched remotely. The exploit is publicly available and might be used. Upgrading to version 2.46 is able to mitigate ...
CVE-2026-100906	New	5.3	MEDI				A vulnerability was detected in Eyeplus 57.0.0.0308. The affected element is the function GetUsers of the file /onvif/Device of the component ONVIF. The manipulation results in information disclosure. The attack can be executed remotely. The exploit is now public and may be used.
CVE-2026-100907	New	5.3	MEDI				A flaw has been found in Eyeplus 57.0.0.0308. The impacted element is an unknown function of the file /snapshot of the component p2pcam Service. This manipulation causes information disclosure. The attack is possible to be carried out remotely. The exploit has been published and may be used.
CVE-2026-101047	New	5.3	MEDI				Fleet before 4.87.0 does not protect the two endpoints that serve in-house iOS application packages and manifests (enterprise tier only) with the intended random, time-limited URL token. Because Apple's InstallEnterpriseApplication MDM command requires these URLs to be reachable without a Fleet session, they cannot rely on session-based authentication, and the missing token ...
CVE-2026-101056	New	5.3	MEDI				Cloudfire before 4.16.1 fails to revalidate share access when restoring cached navigator state from a context_hint UUID. Attackers who previously had valid share access can replay the cached hint to generate signed file URLs for up to 300 seconds after the share is deleted, expires, or reaches zero remaining downloads.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101063	New	5.3	MEDI				Obot versions before v0.23.0 fail to enforce authentication on MCP Registry endpoints under /v0.1/* when registry authentication is enabled. Unauthenticated attackers can read registry metadata including server names, descriptions, repository URLs, and connect URLs by sending GET requests to /v0.1/servers.
CVE-2026-101088	New	5.3	MEDI				Nezha is a server and website monitoring tool. In versions >= 2.2.11 and < 2.3.1, the service sentinel worker (service/singleton/servicesentinel.go) contains an incomplete fix for a previously reported nil dereference denial of service (GHSA-qjpp-gffx-2wm9). The 2026-07-21 fix re-validated the service lifecycle under serviceResponseDataStoreLock but reused an already-capture...
CVE-2026-82841	New	5.3	MEDI		0.001		The UpdraftPlus: WP Backup & Migration Plugin WordPress plugin before 1.26.8, UpdraftPlus: WP Backup & Migration Plugin WordPress plugin before 2.26.8.26 does not have any capability check in a routine that outputs its stored remote storage settings into admin pages when the site is left in a particular post-migration state, allowing any authenticated user, such as a subscri...
CVE-2026-84069	New	5.3	MEDI		0.003		The WebFacing™ WordPress plugin before 5.4 does not restrict access to one of its bundled scripts and does not validate a user-supplied path before using it to include a local file, allowing unauthenticated users to perform Local File Inclusion.
CVE-2026-92436	New	5.3	MEDI		0.002		The Mailchimp for WooCommerce WordPress plugin before 6.3 does not require authentication or verify ownership before loading a saved cart from a request-supplied identifier that is derived from a customer's email address, allowing an unauthenticated attacker who knows a customer's email address to confirm that the customer shops at the store and to read that customer's saved...
CVE-2026-92995	New	5.3	MEDI		0.001		The Verge3D Publishing and E-Commerce WordPress plugin through 4.13.0 does not restrict access to a file-download handler, allowing unauthenticated users to download the digital-goods files attached to any order without authorization.
CVE-2026-96897	New	5.3	MEDI		0.001		The Optima Express IDX WordPress plugin before 8.7.6 does not perform any authorisation check on one of its AJAX actions that is available to logged-out users, allowing unauthenticated attackers to force the creation of a fixed author-role account and to repeatedly rotate its application password on any connected install.
CVE-2026-97165	New	5.3	MEDI				Joomla Extension - svenbluege.de - Reflected XSS and open redirect in Event Gallery extension < 6.5.0 - The "return" parameter is base64-decoded and written to the "Back" link without being validated.
CVE-2026-100747	New	5.1	MEDI				Joomla Extension - svenbluege.de - CSRF in image upload in Event Gallery extension < 6.5.0 - Due to lack of an CSRF token check, a third-party site can upload files to an event and overwrite existing files with the same name.
CVE-2026-100749	New	5.1	MEDI				Joomla Extension - svenbluege.de - CSRF in backend cleanup actions in Event Gallery extension < 6.5.0 - Only orphaned file entries and shopping carts that are older than 30 days will be deleted.
CVE-2026-89001	New	4.9	MEDI		0.001		The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.27 does not verify that a user running a feed campaign is permitted to publish content or to attribute posts to another account, allowing users with contributor-level access and above to publish posts live and set any registered user, including an administrator, as the post author.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101061	New	4.7	MEDI				utcp-gql before 1.1.1 and utcp-websocket before 1.1.1 contain server-side request forgery vulnerabilities due to incomplete application of CVE-2026-44661 fixes. The GraphQL plugin uses a vulnerable prefix check allowing bypass URLs like http://127.0.0.1.attacker.example, while the WebSocket plugin performs no URL validation despite documented security requirements. Attackers...
CVE-2026-86841	New	4.7	MEDI		0.002		The Online Scheduling and Appointment Booking System WordPress plugin before 28.3 does not prevent deserialization of untrusted input and does not correctly restrict a privileged maintenance feature to administrators, allowing users granted a custom booking-management capability, which an administrator must explicitly assign, to inject arbitrary PHP objects, overwrite privi...
CVE-2026-100873	New	4.3	MEDI				A vulnerability was detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. The impacted element is an unknown function. The manipulation results in cross-site request forgery. The attack can be launched remotely. The exploit is now public and may be used. This product does not use versioning. This is why information about affected...
CVE-2026-100877	New	4.3	MEDI				A vulnerability was determined in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. Affected by this vulnerability is an unknown functionality of the file registrationform.php. Executing a manipulation of the argument FName/LName/Addr can lead to cross site scripting. The attack can be executed remotely. The exploit has been publicly di...
CVE-2026-100879	New	4.3	MEDI				A security flaw has been discovered in zhistaredu StarTraining up to 3.8.1. This affects the function checkRoleAllowed of the file SysRoleServiceImpl.java of the component dataScope Endpoint. The manipulation results in missing authorization. The attack may be performed from remote. The exploit has been released to the public and may be used for attacks. The vendor was conta...
CVE-2026-100884	New	4.3	MEDI				A vulnerability has been found in Krayin laravel-crm up to 2.2.5. The impacted element is the function Storage::download of the file packages/Webkul/Admin/src/Config/acl.php of the component attachment-download Endpoint. The manipulation of the argument ID leads to improper control of resource identifiers. The attack may be initiated remotely. The exploit has been disclosed ...
CVE-2026-101033	New	4.3	MEDI				KitchenOwl through 0.7.10 fails to verify that category IDs belong to the caller's household in expense and item operations. Authenticated attackers can enumerate category IDs from other households to read their category names, budgets, and colors, breaking household isolation.
CVE-2026-101087	New	4.3	MEDI				Nezha versions 2.0.10 through 2.3.2 use a restricted HTTP client to validate user-configurable notification and DDNS webhook URLs, but the denylist did not cover IPv6 transition ranges — specifically the 6to4 prefix 2002::/16 and the local-use IPv4/IPv6 translation prefix 64:ff9b:1::/48. Because such addresses satisfy Go's netip.Addr.IsGlobalUnicast check, the URL validator ...
CVE-2026-89000	New	4.1	MEDI		0.001		The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.27 does not perform a capability check or validate the destination of a user-supplied feed URL before fetching it server-side, allowing users with contributor-level access and above to make the server issue requests to internal-only resources and read the responses back.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89003	New	4.1	MEDI		0.001		The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.27 does not perform a capability check before fetching a user-supplied URL and rendering the response, allowing users with contributor-level access and above to force the server to issue requests to internal-only hosts and read the responses back.
CVE-2026-86839	New	3.8	LOW		0.001		The Online Scheduling and Appointment Booking System WordPress plugin before 28.3 does not verify that appointment and payment records requested through its staff-role AJAX actions belong to the requesting staff member, allowing authenticated attackers with a staff-level account to view, modify and delete other staff members' appointments and payments, including the associa...
CVE-2026-100880	New	3.5	LOW				A weakness has been identified in zhistaredu StarTraining up to 3.8.1. This vulnerability affects unknown code of the file du-common/src/main/java/com/edu/common/utis/file/MimeTypeUtils.java of the component Upload Endpoint. This manipulation of the argument File causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been made available...
CVE-2026-100904	New	3.5	LOW				A security vulnerability has been detected in amirsanni mini-inventory-and-sales-management-system up to 81bf0b55f5933f3b0dbb1583204a612e06605b95. Impacted is an unknown function of the file application/controllers/items.php of the component Items Management Module. The manipulation of the argument itemName leads to cross site scripting. Remote exploitation of the attack is ...
CVE-2026-100866	New	3.3	LOW				onfetch through 2.28.1 writes repository information field values to the terminal without removing control characters, allowing terminal escape sequence injection. Attackers can embed ANSI/OSC escape sequences in project manifest version and name fields to manipulate terminal output, rewrite window titles, hide text, or trigger emulator-specific behavior when victims run on...
CVE-2026-100867	New	3.3	LOW				spaceship-prompt through 4.22.5 fails to sanitize control characters from project manifest version fields before rendering them in the zsh prompt. Attackers can embed ANSI/OSC escape sequences in version fields of package manifests to manipulate terminal output, rewrite window titles, or spoof displayed text when victims enter the directory.
CVE-2026-96283	New	3.3	LOW				By calling org.freedesktop.Flatpak.SystemHelper.CancelPull on another user's pull, the pull is not actually cancelled but removed from internal tracking, making it impossible for the owning user to stop it. Ongoing pulls cannot be stopped.
CVE-2026-101046	New	3.1	LOW				Fleet before 4.89.0 contains an SQL injection vulnerability in the activity list endpoints (GET /api/v1/fleet/activities and GET /api/v1/fleet/hosts/{id}/activities). The deprecated cursor-pagination helper appendListOptionsWithCursorToSQL interpolated the caller-supplied sort/order key into the SQL ORDER BY clause without an allowlist, so an authenticated user with read acc...
CVE-2026-101051	New	3.1	LOW				Cloudfire before 4.16.1 fails to properly sanitize file paths returned by remote downloaders, allowing authenticated users to create files outside the selected destination directory. Attackers can exploit path traversal sequences in downloader metadata to write files to unexpected locations within accessible namespaces.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101057	New	3.1	LOW				utcp-mcp (the MCP plugin of python-utcp) through 1.1.2 connects to the HTTP and WebSocket MCP server URLs given in a call template's mcpServers configuration without the ensure_secure_url validation that the HTTP-family plugins apply, so the HTTPS/WSS-or-loopback rule is not enforced. A call template naming a plain-HTTP, non-loopback MCP server URL is dialed as configured, e...
CVE-2026-101089	New	3.1	LOW				Nezha before 2.2.7 contains an information disclosure vulnerability in the GET /api/v1/profile endpoint that returns the bcrypt-hashed password field of authenticated users. Attackers can extract password hashes and perform offline cracking attacks without rate limiting or audit trail constraints.
CVE-2026-96282	New	3.1	LOW				A malicious Flatpak extension can probe the host filesystem to determine what files and directories exist at arbitrary paths, and host directory listings can be disclosed to sandboxed applications using the extension. Additionally, unvalidated extension metadata can cause extension content to be mounted at unintended locations inside the sandbox.
CVE-2026-100881	New	2.6	LOW				A security vulnerability has been detected in zhistaredu StarTraining up to 3.8.1. This issue affects some unknown processing of the file application.yml. Such manipulation of the argument xss.enabled leads to cross site scripting. It is possible to launch the attack remotely. Attacks of this nature are highly complex. The exploitability is assessed as difficult. The exploit...
CVE-2026-96284	New	2.5	LOW				A malicious user can get read-access to files in the flatpak-system-helper context if a system OCI repository is configured, because the OCI code paths in the system helper follow symlinks when importing OCI images that are under the user's control.
CVE-2026-100882	New	2.4	LOW				A vulnerability was detected in Krayin laravel-crm up to 2.2.5. Impacted is an unknown function of the file packages/Webkul/Admin/src/Resources/views/components/layouts/index.blade.php of the component Admin Settings Endpoint. Performing a manipulation of the argument general.settings.footer.label results in cross site scripting. The attack can be initiated remotely. The exp...
CVE-2026-15442	New	2.3	LOW		0.003		In all builds that make use of (D)TLS, including default builds, there is a series of conditional states during the TLS shutdown which could lead to a heap-use-after free. If an application ended up getting a partial wolfSSL_read() which is sometimes caused by a small user buffer passed in, then called wolfSSL_shutdown for a bidirectional close and attempted to wolfSSL_read...
CVE-2026-94417	New	2.3	LOW		0.002		When an application enables both OCSP and CRL revocation checking on one WOLFSSL_CTX or certificate manager, wolfSSL skips the CRL check for any peer certificate that carries no Authority Information Access OCSP URL, and accepts a certificate the loaded CRL lists as revoked. The soft-fail policy for a missing responder collapses the OCSP result onto success before the code d...
CVE-2026-94418	New	2.3	LOW		0.001		Under WOLFSSL_SMALL_CERT_VERIFY, ProcessPeerCertParse() runs the certificate signature check separately from the parse to keep peak memory down, then merges the two results, but it merged the signature result back only when the parse returned 0, so any parse error hid it. ParseCertRelative() reaches its validity-date, name-constraint and critical-extension checks only after ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94419	New	2.3	LOW		0.001		Without NO_SESSION_CACHE_REF, wolfSSL_get_session() does not return a session object but a ClientSession reference of the form {row, index, hash(sessionID)} into the process-global SessionCache, and ClientSessionToSession() validates it against that hash alone. Because the TLS 1.2 session ID is chosen by the server and sent in clear, AddSessionToCache() matches any other ser...
GHSA-5rp9-7r4x-3fqp	New					npm:@const/links	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (9ddcbcb6f472b5dba063f65d700ffb3669e4b33c439ec16445d623240b028202a) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-h37m-2c3q-82j8	New					npm:@digi-kernel/digi-kernel-constrains	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (4cf968a9064d02510a559a3850f8bbda22f6fc038605569e6f6939a139aa115) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
MAL-2026-17193	New					PyPI:metrio	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (f7b0289ef68f815e0fd296282739990dfc918c0070fb5acdae2787ca8eba23f3) Installing the package or importing the module exfiltrates basic information about the host, and the package has no other purpose. --- Category: PROBABLY_PENTEST - Packages looking like typical pentest packages, but also anythi...
MAL-2026-17194	New					PyPI:metrics-sdk	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (60ce93696722d633e9eea7b3fac6f76ebe61a581bd2d1d79efb778f8cb015399) metrics_sdk 999.0.0 is a dependency-confusion beacon. setup.py runs on `pip install` and metrics_sdk/__init__.py runs on `import metrics_sdk`; both hex-encode the installer's hostname into a subdomain label of the form `...
MAL-2026-17195	New					PyPI:claudedashbord	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6e847280dc7dd5b1a2001ec8e048f961b1be2e341889e02233c4f43e48fe0d56) The package installs a.pth file that CPython auto-executes on every Python interpreter startup. The.pth imports claudedashbord.telemetry and calls telemetry.check(), which performs an HTTPS GET to a hardcoded non-publish...
MAL-2026-17196	New					PyPI:donutpromotion	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (26201e7959d7a736440fa6fb22ba7b9911c269b08460374d0a2db307ba6b0273) During installation, obfuscated code is used to fetch code hidden in an image containing a Python application with a native extension module. This module holds an obfuscated infostealer which collects sensitive data and exfiltrate...
MAL-2026-17197	New					PyPI:coinscan	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (021da2d8a1de0971203de68e083eeb30efc18b58ebc5b36ecde89eb03b02cf9e) setup.py imports coinscan.telemetry and calls check() during install. check() fetches a JSON manifest from https://thisisafalsepositive.st/cdn/v2/coinscan/manifest.json (a domain unrelated to any declared publisher), rea...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17198	New					PyPI:caracas4check	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (973d711f03dafa9f390e489476d4795acdda8db926bdd688ca5e1abbe6efa025) The package installs boot.pth at the site-packages root, causing 'import c4c_boot' to run on every Python interpreter startup on the host after installation, not only at install time. c4c_boot.py walks up to 8 parent pro...
MAL-2026-17199	New					PyPI:scrapetools2	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (44124d389269a5e4dc8801d3af1afeb08aee57313fcc7082570c5890e7d89233) scrapetools2 1.2.1 ships an auto-update mechanism in downloader.py that fetches tar.gz payloads from public IPFS gateways (eu.orbitor.dev, dget.top, ipfs.filebase.io) at the author-controlled IPNS name k51qzi5uqu5dmh5178...
MAL-2026-17200	New					PyPI:aseity	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (cf65ea5c0fe1eeef9f47a75d65e291a715094076714694247ad03714eabc53ca) During installation, obfuscated code is used to fetch code hidden in an image containing a Python application with a native extension module. This module holds an obfuscated infostealer which collects sensitive data and exfiltrate...
MAL-2026-17201	New					npm:@bb1ptest23/test-paket	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ossf-package-analysis (b6b02b5a41ef4b1d07f98023a6daa2629818ee31fd68a82af64c9f52f78bec6c) The OpenSSF Package Analysis project identified '@bb1ptest23/test-paket' @ 1.0.3 (npm) as malicious. It is considered malicious because: - The package communicates with a domain associated with malicious activity.

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100656	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		Netty (io.netty:netty-codec-http) contains an unbounded per-connection queue growth flaw in HttpServerCodec. The codec tracks the HTTP method of each still-unanswered pipelined request; the first 32 entries are bit-packed into a single long, but every additional entry is appended to methodOverflowQueue, an ArrayDeque with no size limit and no rejection path. A remote, unauth...
CVE-2026-100657	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty's STOMP codec (io.netty:netty-codec-stomp) contains a ByteBuf leak in StompSubframeDecoder. Once a frame's declared content-length has been fully read, the decoder allocates a chunk buffer from the channel allocator and parks it in an instance field while waiting for the single NUL byte that terminates the frame. If that byte never arrives, the buffer is never released...
CVE-2026-100660	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		Netty's HTTP/3 codec (io.netty:netty-codec-http3) from 4.2.0.Final through 4.2.17.Final retains unbounded per-stream QPACK encoder state. QpackEncoder stores a queue and a dynamic-table index tracker for every encoded field section that references the QPACK dynamic table, keyed by the peer-controlled QUIC stream ID, and these entries are released only when the remote decoder...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100661	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.0.Final through 4.2.17.Final contain a denial-of-service vulnerability in the QPACK prefixed-integer decoder (QpackUtil.decodePrefixedInteger), which does not bound the number of continuation bytes it will process. A remote, unauthenticated peer can open a QPACK unidirectional stream (type 0x02 encoder or 0x03 de...
CVE-2026-100662	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.0.Final through 4.2.17.Final contain an uncontrolled resource consumption vulnerability in the QPACK encoder-stream instruction decoder (QpackEncoderHandler, installed on the peer-initiated unidirectional QPACK encoder stream, type 0x02). The handler accepts an attacker-declared string-literal length of up to Int...
CVE-2026-100663	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty's HTTP/3 codec (io.netty:netty-codec-http3) from 4.2.2.Final through 4.2.17.Final does not special-case HTTP/1 CONNECT authority-form request-targets when converting HTTP/1 messages to HTTP/3 in HttpConversionUtil.toHttp3Headers. The authority-form target (e.g., "CONNECT trusted.example:443") is parsed as a URI, so its host is emitted as :scheme, :path is set to "/", a...
CVE-2026-100664	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.2.Final through 4.2.17.Final builds the HTTP/3 :authority pseudo-header from the HTTP/1 Host header before considering the authority of an absolute-form HTTP/1 request-target. In HttpConversionUtil.toHttp3Headers(HttpMessage, boolean) — reached via Http3FrameToHttpObjectCodec(false) — a non-empty Host header take...
CVE-2026-100665	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.003		Netty versions from 4.2.11.Final before 4.2.18.Final contain an incomplete hostname verification fix in the QUIC certificate verification path when using a plain X509TrustManager. The BoringSSLCertificateVerifyCallback discards the SSLEngine for plain trust managers, preventing endpoint identification from running even when HTTPS verification is configured. Attackers on the ...
CVE-2026-100672	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		The Comments plugin (getgrav/grav-plugin-comments) for Grav CMS through version 1.2.10 registers an admin handler that returns comment data as JSON without any authentication check. The handler branches on isAdmin(), which only indicates that the admin service is registered on the current route rather than that the visitor is authenticated, and it echoes the JSON and calls e...
CVE-2026-100852	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH		0.037		AzuraCast before 0.23.8 contains a command injection vulnerability in the Liquidsoap config generation for live recording that fails to quote the streamer username in process.run calls. Authenticated station users with Streamers and Profile permissions can set a username containing shell metacharacters and trigger command execution as the Liquidsoap process user when recordi...
CVE-2026-100865	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH		0.004		Heym before 0.0.53 evaluates workflow condition expressions using Python's eval() with insufficient sandboxing in the workflow executor service. Authenticated users can edit workflow condition nodes or import malicious templates to execute arbitrary Python and OS commands as the backend process user.
CVE-2026-100841	Updated - CVSS changed (7.8 → 8.5)	8.5	HIGH		0.001		In MONAI 1.6.0, PersistentDataset (monai/data/dataset.py) explicitly rejects the combination track_meta=True with weights_only=True, forcing users who cache MetaTensors (the default tensor type in MONAI >= 1.0) to run torch.load(hashfile, weights_only=False). Related cache helpers in monai/data/utlis.py also call pickle.loads on cached content and derive cache keys with hash...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100673	Updated - CVSS changed (8.2 → 8.4)	8.4	HIGH		0.003		The Grav Data Manager plugin (getgrav/grav-plugin-datamanager) versions 1.0.1 through 1.4.4 render stored data entries in the item-detail view (admin/templates/partial/item.html.twig) without escaping, applying Twig's `raw` filter — in some cases after a striptags(' ') call that PHP's strip_tags() bypasses by preserving allowed tags together with their attributes. An una...
CVE-2026-100655	Updated - CVSS changed (7.5 → 6.9)	6.9	MEDI		0.002		Netty (io.netty:netty-codec-http) versions up to and including 4.1.137.Final and from 4.2.0.Final through 4.2.17.Final accept an unlimited number of concurrent remote-initiated SPDY streams: SpdySessionHandler defaults localConcurrentStreams to Integer.MAX_VALUE and exposes no API to change it. A remote peer that opens a SPDY connection and sends millions of SYN_STREAM frame...
CVE-2026-100658	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI		0.003		Netty (io.netty:netty-codec-http) contains an unbounded per-connection queue in WebSocketServerExtensionHandler. The handler offers an entry to its per-channel validExtensions queue for every inbound HttpRequest, but polls an entry only when the application writes an HttpResponse, and the queue size is never bounded. A remote, unauthenticated peer can use HTTP/1.1 pipelining...
CVE-2026-100659	Updated - CVSS changed (6.5 → 6.9)	6.9	MEDI		0.002		Netty's HTTP/3 codec (io.netty:netty-codec-http3) in versions 4.2.0.Final through 4.2.17.Final does not enforce the RFC 9114 requirement that the :authority pseudo-header field and a literal host header field, when both present, carry the same value. A remote unauthenticated peer can send a single HEADERS frame containing both fields with differing, attacker-controlled value...
CVE-2026-100666	Updated - CVSS changed (7.3 → 6.9)	6.9	MEDI		0.002		Netty's HttpServerCodec (io.netty:netty-codec-http) in versions 4.2.0.Final through 4.2.16.Final and in versions up to and including 4.1.136.Final pairs each outbound response with an inbound request by calling pollMethod() once per response, including for 1xx informational responses. If a client pipelines an HTTP/1.1 GET carrying an Expect: 100-continue header followed by a...

Added to CISA KEV today

None in this window.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88771	New	9.5	CRIT	Yes		citrix:netScaler	Improper input validation vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to an unauthenticated attacker to execute arbitrary commands.
CVE-2026-88772	New	9.5	CRIT	Yes		citrix:netScaler	Vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to Remote Code Execution or Denial of Service

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100886	New	10.0	CRIT				A vulnerability was identified in Seetong T8108, T8108P, T8116 and T8232 4.6.1.4-build202604241011. The affected element is an unknown function of the component Debug Service. Such manipulation leads to improper authentication. The attack may be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101000	New	10.0	CRIT				A vulnerability was determined in Netcore NBR100V2 1.3.240614.030928. This affects the function uci.apply of the file /usr/share/rpcd/acl.d/unauthenticated.json of the component ACL Handler. This manipulation of the argument section causes missing authorization. It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be utilized. The v...
CVE-2026-101001	New	10.0	CRIT				A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This impacts the function eval of the file /www/cgi-bin/network_tools of the component Web Management Interface. Such manipulation of the argument QUERY_STRING leads to os command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used. The vendor was co...
CVE-2026-100896	New	9.9	CRIT				A weakness has been identified in TOTOLINK N150RT 3.4.0-B20201030. The affected element is the function system of the file /boafrm/formWISiteSurvey of the component Web Management Interface. This manipulation of the argument wlanif causes os command injection. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used f...
CVE-2026-100741	New	9.8	CRIT		0.017		Eval injection in the JScript event-script dispatcher in Progressive Robot Ltd's hMailServer, versions 6.0.0 through 6.3.3 on Windows, allows a remote, unauthenticated attacker to run arbitrary JScript inside the hMailServer service process, with the privileges of the service account, via a password containing a backslash followed by an apostrophe, sent in any logon (SMTP AU...
CVE-2026-101065	New	9.8	CRIT				Obot is an open-source AI agent/MCP platform. In all versions up to and including commit d7e6970, the Docker quickstart command documented in the README starts the container listening on 0.0.0.0:8080 with authentication disabled by default. When authentication is disabled, every request is mapped to a synthetic "nobody" user that holds the Owner and Admin roles, so any unaut...
CVE-2026-101090	New	9.8	CRIT				Nezha 2.2.3 contains a Host header injection regression in the OAuth2 redirect endpoint. When the new optional dashboard_host setting is empty, /api/v1/oauth2/{provider} (cmd/dashboard/controller/oauth2.go) reflects the attacker-supplied HTTP Host header into the redirect_uri sent to the identity provider instead of falling back to the configured install_host. An attacker wh...
CVE-2026-101084	New	9.6	CRIT				obot versions before v0.21.1 fail to enforce Access Control Rules on the /mcp-connect endpoint, allowing any authenticated user to connect to restricted MCP servers if they possess the server ID. Attackers can bypass authorization checks to access and manipulate sensitive backend systems through MCP tool calls using stored OAuth credentials.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88773	New	9.3	CRIT				Inconsistent interpretation of HTTP requests ('HTTP Request/Response smuggling') vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1-37.279 and NDcPP; Gateway: before 14.1-73.37 FIPS and before 13.1-64.23.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.